

Dquez Carr

Module 5: Assignment

A hypothetical case study as a pen tester

MCY 670 Web Security

Executive Summary for Northern Kentucky Community Bank

In order to maintain client confidence and meet regulatory requirements, Northern Kentucky Community Bank depends on a complex combination of online banking systems, internal financial services, and customer facing apps, all of which must operate securely. Because we integrate industry standards like OWASP and PTES with real world adversarial testing techniques to provide a complete strategy that goes beyond basic vulnerability scanning, our penetration testing team is uniquely prepared to evaluate these systems. To find vulnerabilities that attackers frequently exploit, we assess authentication methods, access control enforcement, client side exposure, backend components, business logic, datastore interactions, and session management controls. In addition to taking into account insider threats, unauthorized users, compromised customer accounts, and misconfigured infrastructure, our methodology involves brainstorming and modeling potential threats, such as credential misuse, lateral movement, logic bypass, SQL injection, OS command injection, file inclusion, path traversal, and insecure API interactions. We evaluate the potential attack surfaces of Northern Kentucky Community Bank, including web and mobile applications, backend databases, exposed services, APIs, file servers, login and password reset workflows, and multistage banking procedures like loan applications or transfers.

Our team uses an organized intelligence gathering strategy based on PTES principles to start the engagement. To map the bank's digital footprint, count domains and subdomains, find exposed services, and find possible data leaks, we perform a thorough OSINT. After that, we carry out controlled network and application reconnaissance to find open ports, identify parameters that are susceptible to modification, fingerprint server versions, find out-of-date components, count API endpoints, and harvest cookie structures. We create a thorough threat model that includes vital assets, data flows, trust boundaries, and possible chokepoints. Our testing against authentication flows, access control layers, client side manipulation risks, backend execution paths, SQL and second order injection risks, command execution errors, SMTP injection, file inclusion issues, and multi stage logic bypasses is guided by this model.

Our engagement is based on specific expectations: all backend interactions, including databases and file servers, will be fuzzed for injection risks; authentication and MFA will be tested for bypass; horizontal and vertical privilege escalation will be assessed; client side controls will be treated as untrusted; and multistage financial workflows will be tested out of sequence to identify

logic flaws. In order to find response flaws and detection gaps, we also look at monitoring and logging systems.

Our team should be hired by Northern Kentucky Community Bank because we offer a comprehensive, banking-focused viewpoint that combines in-depth technical knowledge with real world understanding of financial sector attack habits. Our deliverables include executive summaries, remediation roadmaps, prioritized risk scoring, proof of concept demonstrations, and comprehensive technical findings. We assist the bank in strengthening confidentiality, maintaining transaction integrity, guaranteeing service availability, and upholding industry standards by proactively identifying vulnerabilities before adversaries can take advantage of them. In a threat landscape that is changing quickly, our strategy supports the bank's dedication to security, dependability, and consumer trust.